

Information Systems Security

Information Systems Security Vulnerabilities

Learning Outcomes

By the end of this lecture, students should be able to:

1. Define a security vulnerability.
2. Differentiate between vulnerabilities, threats, exploits, and risks.
3. Explain the vulnerability lifecycle.
4. Classify different categories of vulnerabilities.
5. Explain software, hardware, operating system, and network vulnerabilities.
6. Analyse real-world vulnerability examples.
7. Recommend appropriate security controls.

Introduction

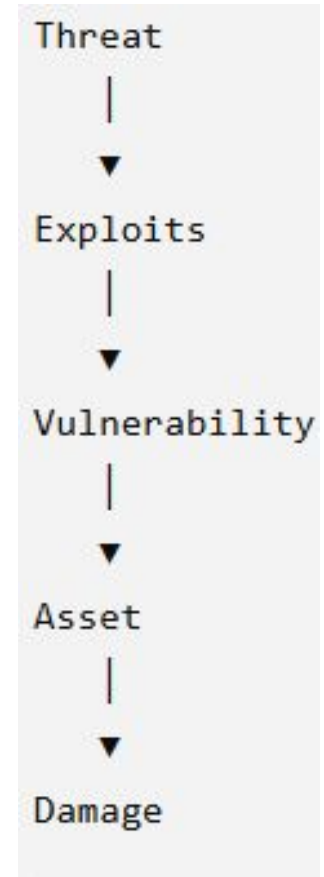
- Modern organisations depend heavily on software applications, computer hardware, communication networks, cloud services, and mobile devices. While these technologies improve efficiency, they also introduce weaknesses that attackers can exploit.
- A single vulnerability can lead to:
 - Data breaches
 - Financial losses
 - Service disruption
 - Reputation damage
 - Legal penalties
 - Loss of customer trust
- Information security professionals must therefore identify, assess, prioritise, and remediate vulnerabilities before they are exploited.

What is a Security Vulnerability?

- **Definition**
- A **security vulnerability** is a weakness or flaw in the design, implementation, configuration, or operation of an information system that can be exploited by a threat actor to compromise the confidentiality, integrity, or availability of information.
- A vulnerability is simply **a weakness that attackers can exploit.**
- Examples: Weak passwords, unpatched operating systems, misconfigured firewalls, SQL injection flaws, buffer overflow bugs, open network ports, missing encryption, outdated antivirus software

Diagram

- **Threat**
 - Cybercriminal
- **Exploit**
 - Password guessing attack
- **Vulnerability**
 - Weak administrator password
- **Asset**
 - Student Information Database
- **Impact**
 - Student records stolen



Why Do Vulnerabilities Exist?

- Vulnerabilities arise due to:
 - Programming mistakes
 - Poor software design
 - Human error
 - Misconfiguration
 - Lack of updates
 - Weak security policies
 - Complex systems
 - Legacy software
 - Third-party software dependencies

Vulnerability Categories

- Information systems contain vulnerabilities in many different areas.
 - Software
 - Hardware
 - Operating Systems
 - Networks
 - Human
 - Physical
 - Cloud
 - Mobile
 - IoT

Software Vulnerabilities

- Software vulnerabilities are flaws in application code or software design.
- These are among the most common causes of successful cyberattacks.
- **Causes**
 - Poor programming
 - Lack of input validation
 - Inadequate testing
 - Incorrect authentication
 - Weak encryption
 - Memory management errors

Buffer Overflow

- Occurs when a program writes more data into memory than allocated
- **Example**
 - Suppose an application expects:
 - 20 characters
 - User enters:
 - 500 characters
 - Without proper validation, memory is overwritten.
- Possible consequences:
 - System crash
 - Privilege escalation
 - Remote code execution

SQL Injection

- Occurs when user input is interpreted as SQL commands.
- Example

```
</> SQL  
  
SELECT *  
FROM Students  
WHERE Username='admin'  
AND Password='password';
```

- Attacker enters:

```
</> SQL  
  
' OR '1'='1
```

- Authentication bypass.

Prevention

- Parameterised queries
- Prepared statements
- Input validation
- Least-privilege database accounts

Authentication Flaws

- Examples include:
 - Weak password policies
 - Predictable session IDs
 - Password reset weaknesses
 - Missing MFA
 - Broken authentication logic

Hardware Vulnerabilities

- Hardware vulnerabilities originate from flaws in processors, firmware, memory, storage devices, or other physical components.
- Although less frequent than software flaws, they can be extremely serious because they often affect millions of devices.
- Examples: Processor design flaws, Firmware vulnerabilities, BIOS weaknesses

Firmware Vulnerabilities and Hardware Security Controls

- Firmware controls hardware operation.
 - Examples:
 - Router firmware
 - SSD firmware
 - BIOS
- Compromised firmware is difficult to detect and remove.
- **Hardware Security Controls**
 - Firmware updates
 - Hardware encryption
 - Physical security
 - Secure disposal of devices

Operating System Vulnerabilities

- Operating systems manage hardware, memory, users, files, and processes.
- A compromised operating system can undermine the security of all applications running on it.
- **Causes:** Unpatched kernels, Misconfigured permissions, Weak default settings, Unnecessary services and Poor privilege separation
- Examples: Weak File Permissions
 - Everyone can read:
 - Payroll.xlsx
 - Clearly:
 - Confidentiality violated.

Outdated Operating Systems

- Windows 7 systems after the end of support.
- Risks include:
 - No security patches
 - Increasing exposure to known exploits
 - Compliance issues

Security Controls

- Regular patching
- Principle of least privilege
- Disable unnecessary services
- Host-based firewalls
- Endpoint Detection and Response (EDR)
- Anti-malware software

Network Vulnerabilities

- Networks connect systems but also provide pathways for attackers.
- **Common Network Vulnerabilities**
 - Open ports
 - Weak Wi-Fi encryption
 - Default router passwords
 - Insecure protocols (e.g., Telnet, FTP)
 - Poor network segmentation
 - Unpatched network devices
- **Example**
 - A router still uses:
 - Username: admin
 - Password: admin
 - An attacker gains administrative access within minutes

Unencrypted Communication

- Using HTTP instead of HTTPS exposes:
 - Usernames
 - Passwords
 - Session cookies
- Attackers on the same network can intercept this information.
- **Poor Network Segmentation**
 - All devices are connected to a single flat network.
 - If one device is compromised, malware can spread rapidly to other systems.

Network Security Controls

- Firewalls
- Intrusion Detection Systems (IDS)
- Intrusion Prevention Systems (IPS)
- Virtual Private Networks (VPNs)
- Network Access Control (NAC)
- Secure protocols (SSH, HTTPS, SFTP)
- VLAN segmentation

Web Application Vulnerabilities

- Web applications have become a critical component of modern organisations.
- Examples: Online banking systems, E-commerce platforms, University Portals
- Because web applications are directly accessible through the Internet, they represent one of the largest attack surfaces.
- A web application vulnerability occurs when weaknesses in application design, coding, authentication, or configuration allow attackers to compromise the application.

OWASP Top 10 Vulnerabilities

- The Open Web Application Security Project (OWASP) publishes the most critical web application security risks.
- The OWASP Top 10 is widely used by developers, security professionals, and organisations.
- <https://owasp.org/Top10/2025/>

1. A01:2025 - Broken Access Control
2. A02:2025 - Security Misconfiguration
3. A03:2025 - Software Supply Chain Failures
4. A04:2025 - Cryptographic Failures
5. A05:2025 - Injection
6. A06:2025 - Insecure Design
7. A07:2025 - Authentication Failures
8. A08:2025 - Software or Data Integrity Failures
9. A09:2025 - Security Logging and Alerting Failures
10. A10:2025 - Mishandling of Exceptional Conditions

Mobile Device Vulnerabilities

- Mobile devices are increasingly used for business operations.
 - Examples: Smartphones, Tablets, Wearables
- Common Mobile Vulnerabilities
 - 1. Weak Authentication
 - Examples: Simple PINs No biometrics, No MFA
 - 2. Insecure Applications
 - Examples: Poor encryption, Excessive permissions, Data leakage
 - 3. Lost or Stolen Devices
 - A lost phone may expose: Emails, Documents, Credentials
- Security Controls
 - Mobile Device Management (MDM)
 - Mobile Device Management (MDM) is a type of security software that lets organizations secure, monitor, manage, and push policies to mobile devices like smartphones, tablets, and laptops from a central platform
 - Device encryption
 - Device encryption scrambles your data into an unreadable format to protect it from unauthorized access if your hardware is lost or stolen.
 - Remote wipe
 - A remote wipe is a security command sent over the internet to delete all data and reset a lost or stolen device
 - Application control
 - A cybersecurity practice that blocks unauthorized software, scripts, and code from running on a computer or network.
 - Biometric authentication
 - Biometric authentication is a security process that verifies your identity using your unique physical or behavioral traits instead of a password or PIN

Human Vulnerabilities

- Humans remain one of the biggest security challenges.
- Social Engineering
 - Attackers manipulate people rather than systems.
- Types
 - Phishing: Fake emails designed to steal information.
 - E.g. "Your bank account has been suspended. Click here."
 - Spear Phishing: Targeted phishing against specific individuals.
 - Pretexting: Creating a false scenario to obtain information.

Human Security Controls

- Security awareness training
- Phishing simulations
- Clear security policies
- Reporting mechanisms

Summary

- Modern information systems face vulnerabilities across multiple layers:
- <https://attack.mitre.org/>

Area	Examples
Web Applications	SQL Injection, XSS, Broken Access Control
Cloud	Misconfiguration
Mobile	Lost devices, insecure apps
IoT	Default passwords, poor updates
Human	Phishing, social engineering
Physical	Theft, unauthorized access